BSIDESTLV 2026 · ALICE IN AI LAND

One Page to Rule Them All

Hijacking MCP Servers Using DNS Rebinding

Avishai Gonen · Yotam Perkal

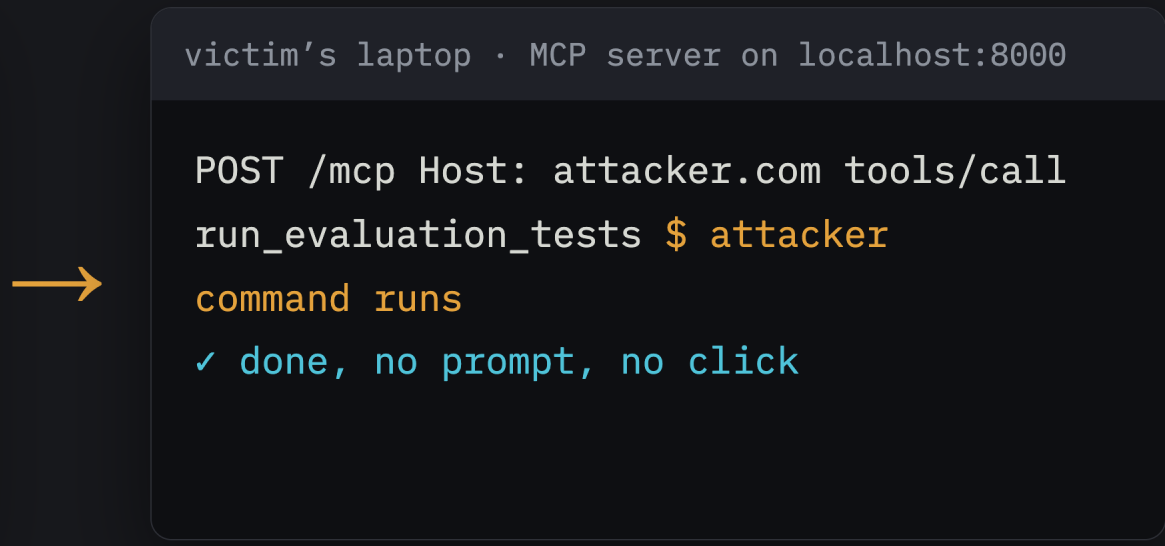
WHAT WE KEPT HEARING

> After reviewing your report, we were unable to identify any security impact. As such, this has been marked as **Not Applicable**.
>
> Although the scenario described may be theoretically possible, it does not represent a realistic or impactful attack under practical, real-world conditions.

A bug bounty triage reply to a DNS rebinding report in an MCP server. We got it more than once.

Open a webpage. The attacker's code runs.





WHO WE ARE



Avishai Gonen

A cyber security researcher. In my free time I do CTFs, bug bounty, and independent research. 30+ CVEs to my name, found as a vulnerability researcher at Pluto Security.



Yotam Perkal

Leads security research at Pluto Security. Previously led Threat Research at Zscaler, Vulnerability Research at Rezilion, and security roles at PayPal. Active in AI-security and supply-chain working groups.

DOWN THE RABBIT HOLE

“Down, down, down. Would the fall never come to an end?”

Lewis Carroll, Alice’s Adventures in Wonderland, 1865 · Illustration: John Tenniel

“...Alice had begun to think that very few things indeed were really impossible.”



CVE-2026-55637

CVE-2026-55642

CVE-2026-61542

CVE-2026-61546

CVE-2026-61559

CVE-2026-81735

CVE-2026-61742

CVE-2026-61568

CVE-2026-76807

CVE-2026-77318

50+

CVEs & advisories

one bug class

CVE-2026-77329

CVE-2026-77339

CVE-2026-81101

CVE-2026-77359

CVE-2026-81092

CVE-2026-81097

CVE-2026-81095

CVE-2026-81099

CVE-2026-81096

CVE-2026-81098

CVE-2026-92149

MCP

Model Context Protocol

The standard way AI agents reach your tools, files, and APIs.

Many MCP servers run on your own laptop, and listen on localhost.

HOW MCP SERVERS LISTEN

Two transports, two very different doors

“There were doors all round the hall, but they were all locked.”

`stdio`

The client starts the server as a child process and talks over stdin and stdout.

No network port. A browser cannot reach it.

`Streamable HTTP / SSE`

The server listens on a port, like http://localhost:8000/mcp, and takes JSON-RPC over POST.

Anything that can send HTTP to that port can talk to it.



Localhost is a tiny door. Authors assume only local apps can fit through it.

“It’s on localhost, so only local apps can reach it.”

DNS rebinding

Nothing that breaks this assumption is new.

ADVICE FROM A CATERPILLAR

“Who are you?”

“At least I know who I was when I got up this morning, but I think I must have been changed several times since then.”

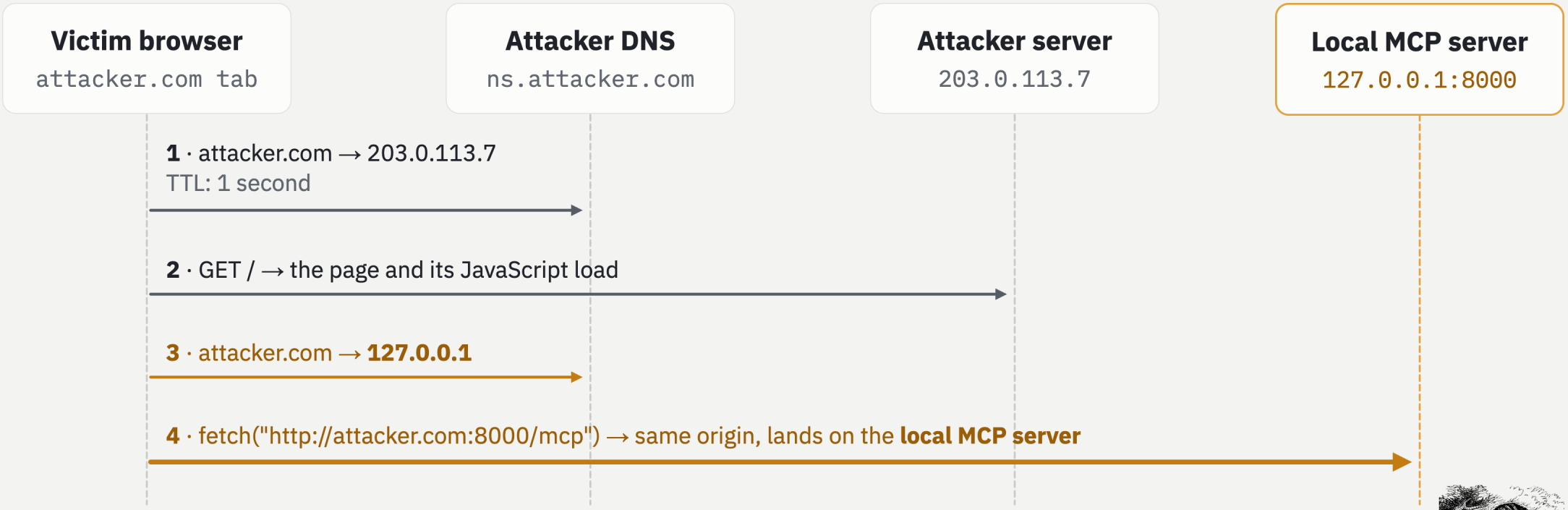
Alice, to the Caterpillar · Illustration: John Tenniel

```
attacker.com, a minute ago → 203.0.113.7
attacker.com, now → 127.0.0.1
```



DNS REBINDING

How it works



The browser trusts the **hostname**, not the IP behind it. The grin without the cat.



THE DEAD END

Small enough for the door. The key was out of reach.

Rebound page → **attacker.com** wants to access other apps and services on this device — Block / Allow — ✗ **Chrome asks the user**

Rebound page → [icon: Puzzle] **Extension with host permissions:** exempt from the prompt — ✓ **localhost, no prompt**



Chrome 142 · Edge 143 · Firefox 153: **ask**

Brave: **blocks**

Safari: **no loopback check**

Extensions: **exempt**

THE CAST

3 case studies

The Duchess's baby

CircleCI

Rebinding + command injection. **Two vulns chained** to RCE.

`CVE-2026-95855`
`CVE-2026-95856`

The Knave of Hearts

Docker Hub

Rebinding to credential abuse. The server **acts as you**.

`GHSA-j65h-q28x-6rhf`

Tweedledum & Tweedledee

mcp-go

One unsafe SDK default, **inherited by many**.

`CVE-2026-81092`

BEFORE THE DEMOS

We'll show that opening one webpage is enough for an attacker to take control of an MCP server running on the victim's own machine.

The victim

A developer laptop running a local MCP server over HTTP, with the developer's own token.

The attacker

Owns a domain and its DNS server, and hosts one webpage.

The victim's part

Opens the link. **That's it.** No clicks, no downloads, no prompts.

CASE STUDY 1 · CIRCLECI

“This time there could be no mistake about it: it was neither more nor less than a pig.”

Lewis Carroll, Alice’s Adventures in Wonderland, 1865 · Illustration: John Tenniel

A file name goes in. A command comes out.



CASE STUDY 1 · CIRCLECI

Rebinding into the local server

- The server holds the developer's CircleCI **token**
- A malicious page rebinds and talks to it as **localhost**
- 17 tools exposed: drive the victim's CI/CD, **no auth**
- Run pipelines, rerun workflows, roll back deployments

CVE-2026-95855 · GHSA-jwj7-74jh-p5c4 · CVSS 3.1 8.3

Fixed in @circleci/mcp-server-circleci 0.17.0 (Host and Origin validation)

CASE STUDY 1 · CIRCLECI

A filename, straight into the shell

```
fileName: z.string() // no allowlist
python eval.py ${file.fileName}
```

Unauthenticated RCE via the **run_evaluation_tests** tool, inside CircleCI's runner, with **$CIRCLE_TOKEN** and the pipeline's secrets.

CVE-2026-95856 · GHSA-m9x7-h9px-p447 · CVSS 3.1 10.0

Fixed in 0.16.1: allowlist the filename, quote it, and turn auth on by default

LIVE DEMO 1

Chaining the two: rebind → RCE

CVE-2026-95855 + CVE-2026-95856

CASE STUDY 2 · DOCKER HUB

“The Knave of Hearts, he stole those tarts, and took them quite away!”

Lewis Carroll, Alice’s Adventures in Wonderland, 1865 · Illustration: John Tenniel

The server holds the keys, and spends them for whoever asks.



CASE STUDY 2 · DOCKER HUB

The server spends your credentials for you

Attacker's JavaScript
In the victim's browser tab. Has no token.

→

hub-mcp on localhost
Holds the victim's Docker Hub PAT.

→

Docker Hub API
Sees a normal request from the victim.

- Enumerate private namespaces, organizations and repository metadata
- Call **createRepository** and **updateRepositoryInfo** as the victim
- The token never reaches attacker JS. This is a **supply-chain** risk: a tampered image in a trusted namespace.

GHSA-j65h-q28x-6rhf · CVSS 4.0 8.3 · High

Affects --transport=http, 0.1.0 to 0.18.0. Fixed in 0.19.0. The default stdio mode is not affected.

LIVE DEMO 2

Docker Hub: use the victim’s credentials

GHSA-j65h-q28x-6rhf

THROUGH THE LOOKING-GLASS · MCP-GO

“When I use a word, it means just what I choose it to mean, neither more nor less.”

Humpty Dumpty, Through the Looking-Glass, 1871 · Illustration: John Tenniel

To the server, a Host header means whatever the attacker says it means.



THE SDK ANGLE

One unsafe default

mark3labs/mcp-go, 9,000+ GitHub stars, dispatches on the HTTP method alone. No default Host or Origin allowlist. CVE-2026-81092 · CVSS 4.0 7.6

```
// server/streamable_http.go, v0.40.0
func (s *StreamableHTTPServer) ServeHTTP(
    w http.ResponseWriter, r *http.Request) {
  switch r.Method {
  case http.MethodPost:   s.handlePost(w, r)
  case http.MethodGet:    s.handleGet(w, r)
  case http.MethodDelete: s.handleDelete(w, r)
  default:                http.NotFound(w, r)
  }
}
// That's the whole handler. No Host, no Origin.
```

```
curl http://127.0.0.1:8080/mcp \
  -H 'Host: attacker.example' \
  -H 'Origin: http://attacker.example' \
  -H 'Content-Type: application/json' \
  -d '{"jsonrpc":"2.0","id":2,
       "method":"tools/call", ...}'

→ 200 OK. Session created, tool runs.
  No auth. No questions.
```

Fixed in 0.56.0: new server/http_localhost.go rejects loopback requests that name a non-loopback host, on both transports.

THE SDK ANGLE

...and it spread

Tweedledum

Azure/mcp-kubernetes

Microsoft-maintained. Inherited the default: kubectl from a browser tab. Disclosed to MSRC.

Tweedledee

A second, unrelated MCP server

Inherited the same default. Disclosed separately.



Same root cause. Neither maintainer wrote the bug. The default handed it to them.

+ every other server built on that default

THE QUEEN'S COURT

"Off with their headers!"

The Queen of Hearts, more or less · Illustration: John Tenniel

Zero trust for localhost: check the Host, check the Origin, demand a token.



DNS REBINDING

The fixes that work

1 · Validate Host

Accept only localhost, 127.0.0.1 and [::1] on your port. After a rebind the request says **Host: attacker.com**. Reject it.

2 · Validate Origin

Reject browser requests from an Origin you don't expect. The rebinding page sends its own: **http://attacker.com**.

3 · Require auth

A per-install token the webpage can't know. **Local is not a credential.**

Why CORS doesn't help

After the rebind, the page and the "server" share one origin: attacker.com. The browser sees a same-origin request, so CORS is never asked.

The MCP spec already says it: *"Servers **MUST** validate the Origin header on all incoming connections to prevent DNS rebinding attacks."*

“You’re nothing but a pack of cards!”

DNS rebinding is the new door. What’s behind it is decades old.

Bug class	Behind an MCP server	Example
Command injection	Builds a shell command from caller input	CircleCI: run_evaluation_tests (CVSS 10.0)
SSRF	Sends requests to a URL the caller controls	mcp-atlassian: X-Atlassian-Jira-Url header (CVE-2026-27826)
Path traversal	Writes to a path the caller supplies	mcp-atlassian: confluence_download_attachment (CVE-2026-27825)
Missing auth	Exposes powerful tools to anyone who connects	nginx-ui: /mcp_message (CVE-2026-33032, exploited in the wild)

Unauthenticated tools reach file systems, cloud APIs, CI runners and even physical devices. Forgotten MCP servers make it worse: nobody knows what’s running, what it can reach, or whether anyone reviewed it.



“Why, sometimes I’ve believed as many as six impossible things before breakfast.”

The White Queen, Through the Looking-Glass, 1871 · Illustration: John Tenniel

AS AN ATTACKER, I COULD...

1 Reach localhost from one webpage

2 Get past the browser’s guard

3 Run commands through CircleCI

4 Spend the victim’s Docker Hub token

5 Hand the bug to servers that never wrote it

6 Find it in 50+ CVEs

ONE LAST THING

Secure your MCP servers like production

Treat every local MCP server as external attack surface.

It wasn't a dream. It's your localhost.

Avishai Gonen · Yotam Perkal

Slides, demos & write-ups